

REPORT

PENETRATION TESTING

Merdeka Bank Web Application

Disiapkan untuk:

PT Merdeka Bank – Indonesia





MERDEKA SIBER

PT MERDEKA SIBER TEKNOLOGI

Jl. Bulak Indah, Jakarta 13910

Phone +62 813 8621 5006

CONFIDENTIAL



KONTROL DOKUMEN

Catatan Perubahan

Tanggal	Versi	Penulis	Deskripsi
18-11-2025	1.0	Muhammad Hibatullah Wafi	Report Penetration Testing Tahap 1 – Merdeka Bank

Review and Approval

	Nama	Tanggal	Paraf
Merdeka Siber	Danang Tri Atmaja	19-11-2025	
	Leo Walidi	19-11-2025	
Merdeka Bank	Andi Setiawan	19-11-2025	

PERNYATAAN

Informasi yang disajikan dalam dokumen ini diberikan sebagaimana adanya dan tanpa jaminan. Penetration testing adalah analisis dalam waktu tertentu dan dengan demikian dimungkinkan bahwa sesuatu di lingkungan dapat berubah sejak pengujian yang tercermin dalam laporan ini dijalankan. Ada kemungkinan bahwa temuan kerentanan baru mungkin telah ditemukan sejak pengujian dijalankan. Karena alasan ini, laporan ini harus dianggap sebagai panduan, bukan representasi 100% dari risiko yang mengancam sistem, jaringan, dan aplikasi Anda.

DAFTAR ISI

KONTROL DOKUMEN	2
PERNYATAAN	3
DAFTAR ISI	4
DETAIL PROJEK	5
1.1 RUANG LINGKUP	5
1.2 TIMELINE	5
1.3 AREA	5
1.4 METODOLOGI	5
1.5 JENIS KERANGKA DAN UJI PENETRASI	6
RINGKASAN EKSEKUTIF	8
TEMUAN	10
1.6 TEMUAN DOMAIN HTTP://217.216.109.97/	10
1.6.1 Weak Authentication Scheme	10
1.6.2 Insecure Direct Object Reference	14
1.6.3 Authentication Bypass	19
1.6.4 Information Disclosure	23
1.6.5 Insecure Direct Object Reference	26
1.6.6 Insecure Direct Object Reference	29
1.6.7 Business Logic Flaw	33
1.6.8 Unrestricted File Upload	37
1.6.9 Cross-Site Scripting (XSS) – Reflected	40
1.6.10 Cross-Site Scripting (XSS) – Stored	44
1.6.11 Information Disclosure	49
CLOSING	54

DETAIL PROJEK

1.1 Ruang Lingkup

Ruang lingkup objek dari proyek ini adalah Web Application.

No	Aplikasi	Akses
1	http://217.216.109.97:43705/	Internet

1.2 Timeline

Kegiatan pengujian keamanan aplikasi dilakukan dalam x Hari.

Berikut merupakan gambaran berupa table akan kegiatan pengujian yang telah dilakukan :

Aktifitas	Kategori	Dari	Sampai	Lokasi
Penetration Testing	Website	14-11-2025	18-11-2025	Jakarta

1.3 Area

Kegiatan pengujian penetrasi dilakukan dari area eksternal.

1.4 Metodologi

Metodologi pengujian penetrasi yang digunakan dalam proyek ini dijelaskan di bawah ini,

1. Blackbox Testing

Alamat IP, URL, atau nama domain diberikan untuk kegiatan utama, yang bertujuan untuk mengetahui celah keamanan yang mungkin terpapar pada aplikasi seluler, server, dan/atau layanan pendukung aplikasi.

1.5 Jenis Kerangka dan Uji Penetrasi

Di bawah ini adalah penjelasan untuk tipe penetrasi yang diusulkan,

Web application penetration testing ini bertujuan untuk mensimulasikan apa yang dapat dilakukan peretas, yaitu mengidentifikasi dan mengeksploitasi kerentanan dalam sistem, jaringan, dan perangkat jaringan. Jaringan terbaik digunakan untuk menemukan setiap lubang keamanan sebelum peretas/pengguna yang tidak berwenang mendapatkannya terlebih dahulu.

Hasil identifikasi dan verifikasi oleh konsultan kemudian akan dilanjutkan dengan memberikan rekomendasi strategi keamanan untuk melindungi data sensitif dan mencegah pengambil alihan sistem oleh pihak jahat.

Konsultan mengacu pada framework Penetration Testing Execution Standard (PTES) untuk melakukan pengujian ini. yang mana termasuk,



- **Pengumpulan Intelijen,**

Eksplorasi dan pengungkapan informasi tentang sistem yang dapat diakses beserta layanan yang berjalan di dalam aplikasi.

- **Pemodelan Ancaman,**

Identifikasi kerentanan yang ada di sistem melalui pemindaian otomatis atau manual.

- **Analisis Kerentanan,**

Proses dokumentasi dan analisis terkait kerentanan yang ditemukan untuk eksploitasi/serangan selanjutnya.

- **Eksplorasi**

Proses verifikasi kerentanan dengan meluncurkan teknik serangan mendalam, untuk mendapatkan informasi berharga atau hak akses terbatas.

- **Pelaporan**

Dokumentasi aktivitas jaringan terbaik, temuan dengan bukti, penentuan tingkat risiko, dan rekomendasi yang berguna untuk perbaikan temuan pada sistem.

CONFIDENTIAL

RINGKASAN EKSEKUTIF

Berikut adalah ringkasan temuan celah keamanan pada aplikasi Merdeka Bank Web Application dengan kategori Domain sebagai berikut.

No.	Nama Temuan	Object	Severity Level	Status
1	<i>Weak Authentication Scheme</i>	Website	CRITICAL	Open
2	<i>Insecure Direct Object Reference</i>	Website	CRITICAL	Open
3	<i>Authentication Bypass</i>	Website	CRITICAL	Open
4	<i>Information Disclosure</i>	Website	HIGH	Open
5	<i>Insecure Direct Object Reference</i>	Website	HIGH	Open
6	<i>Insecure Direct Object Reference</i>	Website	HIGH	Open
7	<i>Business Logic Flaw</i>	Website	HIGH	Open
8	<i>Unrestricted File Upload</i>	Website	MEDIUM	Open
9	<i>Cross-Site Scripting (XSS) - Reflected</i>	Website	MEDIUM	Open

10	<i>Cross-Site Scripting (Stored)</i>	Website	MEDIUM	Open
11	<i>Information Disclosure</i>	Website	LOW	Open

CONFIDENTIAL

TEMUAN

1.6 Temuan Domain <http://217.216.109.97/>

1.6.1 Weak Authentication Scheme

Weak Authentication Scheme	
Severity	CRITICAL (9.8)
CVSS Score 3.1	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
Deskripsi	Weak Authentication Scheme (Skema Otentikasi yang Lemah) adalah kegagalan desain yang fundamental pada cara aplikasi melindungi data sensitif dan memverifikasi identitas pengguna. Ini terjadi ketika aplikasi menggunakan algoritma, protokol, atau implementasi kriptografi yang sudah usang, tidak aman, atau dirancang dengan buruk. Dalam hal ini ada 3 kerentanan utama yang kami temukan di website yaitu 1. OTP memiliki pola yang mudah ditebak (1006, 1007, 1008, dst.). OTP tidak dihasilkan secara acak atau kriptografis, melainkan sequential atau berdasarkan urutan (<i>incrementing</i>).

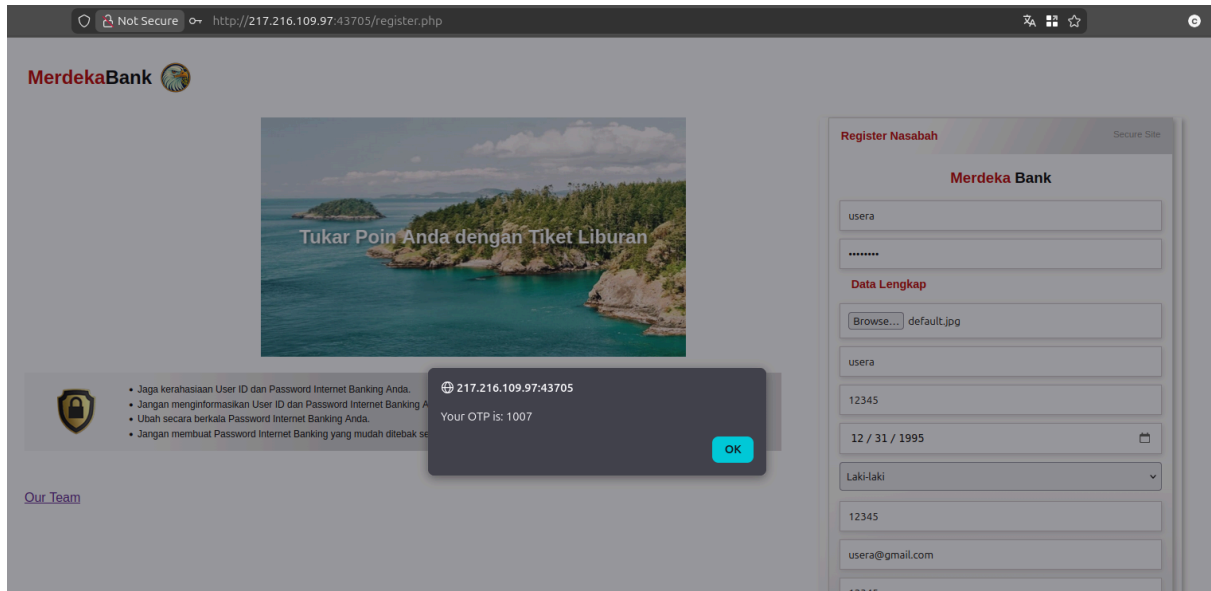
	2. OTP berlaku selamanya dan tidak dapat dihapus atau diperbarui. Ini menghilangkan tujuan utama dari <i>One-Time Password</i> (sekali pakai). 3. Verifikasi OTP tidak dibatasi jumlah percobaannya. Ini memungkinkan penyerang untuk melakukan <i>Brute Force Attack</i> tanpa hambatan.
Affected URL	http://217.216.109.97:43705/otp.php
Dampak	Pengambilalihan Akun (Account Takeover): - OTP 4 digit hanya memiliki 10.000 kemungkinan. - Karena tidak ada <i>rate limiting</i> dan polanya tertebak, penyerang dapat menemukan kode yang benar secara instan atau dalam waktu yang sangat singkat menggunakan skrip otomatis, sehingga melewati proses verifikasi atau otentikasi multifaktor (MFA). Pelanggaran Data: Setelah berhasil mengambil alih akun, penyerang dapat mengakses dan mencuri data pribadi (<i>Personally Identifiable Information/PII</i>) pengguna lain. Kerugian Reputasi: Kegagalan fatal pada mekanisme keamanan inti seperti OTP akan merusak reputasi perusahaan secara permanen.

Kategori	Website
Rekomendasi	• Perkuat Generasi OTP dibuat lebih panjang menjadi 8 karakter dan tanpa pola tertentu supaya lebih sulit ditebak, atau gunakan third party authenticator • Buat Ekspirasi untuk OTP OTP memiliki masa berlaku yang singkat seperti 1 - 5 menit dan setelah kadaluarsa langsung dihapus • Implementasi rate limit Input OTP yang salah harus dibatasi, misalnya setiap kesalahan input diberikan delay 10, 30, 60 detik sebelum input selanjutnya, lalu input salah berulang bisa mengakibatkan pemblokiran akun
Referensi	• OWASP A07:2021 - Identification and Authentication Failures (https://owasp.org/Top10/A07_2021-Identification_and_Authentication_Failures/) • CWE-307: Improper Restriction of Excessive Authentication Attempts (https://cwe.mitre.org/data/definitions/307.html) • NIST SP 800-53 (https://csrc.nist.gov/publications/sp-800-53) • CAPEC-113: Excessive Attack on Authenticator

(<https://capec.mitre.org/data/definitions/113.html>)

Bukti Temuan

OTP yang diberikan hanya 4 Digit



OTP dapat di-brute force tanpa rate limit

Attack Save 3. Intruder attack of http://217.216.109.97:43705

Results Positions

Capture filter: Capturing all items Apply capture filter

View filter: Showing all items

Request	Payload	Status code	Response received	Error	Timeout	Length	Comment
1	1000	200	52			464	
2	1001	200	102			464	
3	1002	200	121			463	
4	1003	200	102			464	
5	1004	200	102			464	
6	1005	200	102			464	
7	1006	200	102			515	
8	1007	200	102			464	
9	1008	200	102			464	
10	1009	200	102			464	
11	1010	200	72			464	
12	1011	200	55			464	
13	1012	200	45			464	
14	1013	200	102			464	
15	1014	200	55			464	
16	1015	200	102			464	
17	1016	200	70			464	
18	1017	200	102			464	
19	1018	200	99			464	
20	1019	200	80			464	
21	1020	200	102			464	
22	1021	200	102			464	

Request Response

Pretty Raw Hex Render

```

1 HTTP/1.1 200 OK
2 Date: Mon, 17 Nov 2025 18:24:40 GMT
3 Server: Apache/2.4.56 (Debian)
4 X-Powered-By: PHP/8.0.30
5 Access-Control-Allow-Origin: *
6 Access-Control-Allow-Methods: GET, POST, OPTIONS, PUT, DELETE
7 Access-Control-Allow-Headers: Content-Type, Authorization, X-Requested-With
8 Content-Length: 62
9 Keep-Alive: timeout=5, max=100
10 Connection: Keep-Alive
11 Content-Type: text/html; charset=UTF-8
12
13 {"status":"error","message":"OTP tidak valid untuk akun ini."}
    
```

Status
OPEN

1.6.2 Insecure Direct Object Reference

Insecure Direct Object Reference	
Severity	CRITICAL (8.8)
CVSS Score 3.1	CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H
Deskripsi	Insecure Direct Object Reference (IDOR) adalah jenis kerentanan kontrol akses di mana aplikasi web mengekspos referensi langsung ke objek implementasi internal, dan gagal memverifikasi bahwa pengguna memiliki otorisasi untuk mengakses objek tersebut. Dalam hal ini ketika pengetesan kami bisa melakukan mengubah request pengiriman dana dari sisi pengirim dan penerima
Affected URL	http://217.216.109.97:40477/dashboard.php
Dampak	• Pencurian Dana / Fraud: Ini adalah dampak langsung. Penyerang dapat mengalihkan dana dari rekening korban ke rekening mereka sendiri,

	menyebabkan kerugian finansial yang parah bagi korban dan platform. • Horizontal Privilege Escalation: Penyerang secara efektif "mengakses" (memanipulasi) data transaksi yang seharusnya ditujukan untuk entitas lain. • Kerugian Reputasi & Kepatuhan: Insiden keamanan yang melibatkan pencurian dana akan menyebabkan denda regulasi yang besar (tergantung yurisdiksi) dan hilangnya kepercayaan pelanggan secara total. • Manipulasi Data: Jika ada kepentingan tertentu, transaksi fiktif bisa dibuat contoh untuk perbaikan angka pembukuan atau framing kejahatan terhadap pemilik rekening tertentu.
Kategori	Website
Rekomendasi	• Verifikasi Kontrol Akses Setiap kali <i>input</i> pengguna digunakan untuk mengambil objek dari <i>database</i> server harus secara eksplisit memeriksa bahwa ID pengguna yang saat ini login adalah pemilik objek yang diminta. • Gunakan Indirect Reference Maps Agar tidak mengekspos ID database secara

	langsung (misalnya, <code>?id=123</code>), gunakan identifier yang tidak dapat diprediksi (unpredictable) seperti UUID (Universally Unique Identifier) atau reference map yang terpisah. • Berikan Batasan dan Validasi Terhadap Aktivitas Akun Dilakukan agar bisa terdeteksi apabila ada aktivitas akun mencurigakan seperti transfer terlalu besar, terlalu sering, dll
Referensi	• OWASP A01:2021 – Broken Access Control (https://owasp.org/Top10/A01_2021-Broken_Access_Control/) • CWE-639: Authorization Bypass Through User-Controlled Key (https://cwe.mitre.org/data/definitions/639.html) • NIST 800-53 (https://csrc.nist.gov/publications/sp-800-53) • CAPEC-49: Input Data Manipulation (https://capec.mitre.org/data/definitions/49.html) • OWASP IDOR Prevention Cheat Sheet (https://cheatsheetseries.owasp.org/cheatsheets/Insecure_Direct_Object_Reference_Prevention_Cheat_Sheet.html)

Bukti Temuan

Terdapat fitur “Transfer Dana” pada halaman /dashboard.php

The screenshot shows the 'Merdeka Bank' dashboard at the URL `http://217.216.109.97:40477/dashboard.php`. The user is logged in as 'user'. The 'Transfer Dana' feature is highlighted in the sidebar. The main content area shows the 'Transfer Bank' section with the following details:

- Sumber Dana:** Merdeka Bank Savings
- Nomor Rekening:** 6223456789017
- Nama:** Merdeka Bank Savings
- Mata Uang:** IDR
- Saldo Tersedia:** Rp 6.712.830,00
- Rekening Tujuan:** 6223456789012
- Transaction For:** Investasi
- Deskripsi:** test
- Jumlah Transfer:** 10000

A red 'Transfer' button is located at the bottom right of the form.

Menggunakan Burpsuite Intercept, parameter `{account_id}`, `{account_to}` dan `{amount}` pada request transfer dana dapat diubah yang akan merubah rekening asal, rekening tujuan dan jumlah transfer sesuai urutan

Laporan Penetration Testing – Merdeka Bank Web Application

1

Burp Project

Intruder

Repeater

View

Help

Dashboard

Target

Proxy

Intruder

Repeater

Collaborator

Sequencer

Decoder

Comparer

Logger

Organizer

Extensions

Intercept

HTTP history

WebSockets history

Match and replace

Proxy settings

Intercept on

Forward all

Drop

Request to http://217.216.109.97:40477

Open browser

Time	Type	Direction	Method	URL	Status code	Length
07:27:01.18 No...	WS	→ To server		https://web.whatsapp.com/ws/chat?ED=CA0Aggl		42
07:27:06.18 No...	WS	← To client		https://tryhackme.com/socket.io/?EIO=4&transport=websocket		1
07:27:09.18 No...	WS	→ To server		https://nexus-websocket-a.intercom.io/pubsub/5-OPPNQbsNCa_BK-5x0nDFfy-ghab9Nlxq/Uka4YKggymQmBjYOeU_Mllo308IgrPcQdOsLURdK1_scgQc2UmueSPdDembDu7X-Nexus-New-Clien...		251
07:27:11.18 No...	HTTP	→ Request	POST	http://217.216.109.97:40477/api/routes/api.php?route=transactions-create		
07:27:24.18 No...	WS	→ To server		https://web.whatsapp.com/ws/chat?ED=CA0Aggl		210
07:27:24.18 No...	WS	← To client		https://web.whatsapp.com/ws/chat?ED=CA0Aggl		39
07:27:24.18 No...	WS	← To client		https://web.whatsapp.com/5222/news/chat?ED=CA0Aggl		4
07:27:28.18 No...	WS	← To client		https://tryhackme.com/socket.io/?EIO=4&transport=websocket		107
07:27:34.18 No...	WS	← To client		https://web.whatsapp.com/ws/chat?ED=CA0Aggl		4
07:27:52.18 No...	WS	← To client		https://tryhackme.com/socket.io/?EIO=4&transport=websocket		107
07:28:17.18 No...	WS	→ To server		https://nexus-websocket-a.intercom.io/pubsub/5-OPPNQbsNCa_BK-5x0nDFfy-ghab9Nlxq/Uka4YKggymQmBjYOeU_Mllo308IgrPcQdOsLURdK1_scgQc2UmueSPdDembDu7X-Nexus-New-Clien...		46
07:28:17.18 No...	WS	← To client		https://tryhackme.com/socket.io/?EIO=4&transport=websocket		107
07:28:43.18 No...	WS	← To client		https://tryhackme.com/socket.io/?EIO=4&transport=websocket		107
07:29:08.18 No...	WS	← To client		https://tryhackme.com/socket.io/?EIO=4&transport=websocket		107
07:29:18.18 No...	WS	→ To server		https://push.services.mozilla.com/		153
07:29:32.18 No...	WS	← To client		https://tryhackme.com/socket.io/?EIO=4&transport=websocket		107
07:29:41.18 No...	WS	→ To server		https://nexus-websocket-a.intercom.io/pubsub/5-OPPNQbsNCa_BK-5x0nDFfy-ghab9Nlxq/Uka4YKggymQmBjYOeU_Mllo308IgrPcQdOsLURdK1_scgQc2UmueSPdDembDu7X-Nexus-New-Clien...		46
07:29:43.18 No...	WS	→ To server		https://push.services.mozilla.com/		153
07:29:58.18 No...	WS	← To client		https://tryhackme.com/socket.io/?EIO=4&transport=websocket		107
07:30:28.18 No...	WS	→ To server		https://push.services.mozilla.com/		153
07:30:29.18 No...	WS	← To client		https://tryhackme.com/socket.io/?EIO=4&transport=websocket		107

Request

Pretty

Raw

Hex

```
14 .....geckoformboundary4f0224ae008b22436c674a9509f3db64
15 Content-Disposition: form-data; name="account_id"
16
17
18 6223456789012
19 .....geckoformboundary4f0224ae008b22436c674a9509f3db64
20 Content-Disposition: form-data; name="account_to"
21
22
23 6223456789015
24 .....geckoformboundary4f0224ae008b22436c674a9509f3db64
25 Content-Disposition: form-data; name="amount"
26
27
28 5000000
29 .....geckoformboundary4f0224ae008b22436c674a9509f3db64
30 Content-Disposition: form-data; name="transaction_for"
31
32
33 investment
34 .....geckoformboundary4f0224ae008b22436c674a9509f3db64
35 Content-Disposition: form-data; name="description"
36
37
38 test
39 .....geckoformboundary4f0224ae008b22436c674a9509f3db64
```

Inspector

Request attributes

Request query parameters

Request body parameters

Request cookies

Request headers

setelah diforward maka transfer akan berhasil

Merdeka Bank

Selasa, 18 November 2025 07:32:29

Selamat Datang, user

Transfer Dana > Ke Rekening Bank

Informasi Rekening

Transfer Dana

Ke Rekening Bank

Transfer Bank

Sumber Dana

Nomor Rekening

6223456789017

Nama

Merdeka Bank Savings

Mata Uang

IDR

Saldo Tersedia

Rp 6.712.830,00

Rekening Tujuan

6223456789012

Rekening Tujuan/Virtual Account

Transaction For

Investasi

Deskripsi

test

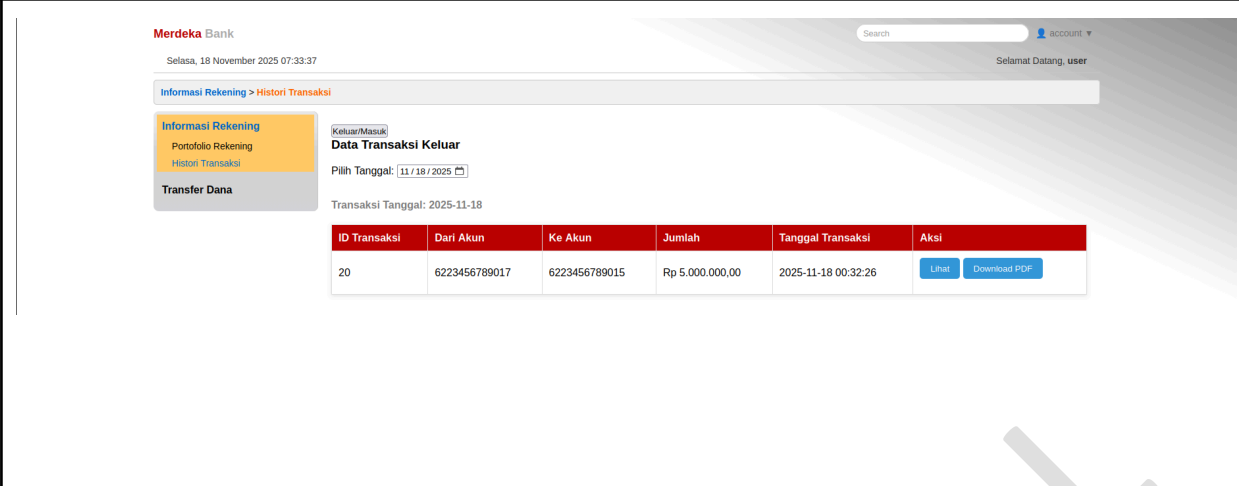
Jumlah Transfer

10000

Transaction successful!

Transfer

dan dapat dikonfirmasi pada history transaksi

	
Status	
OPEN	

1.6.3 Authentication Bypass

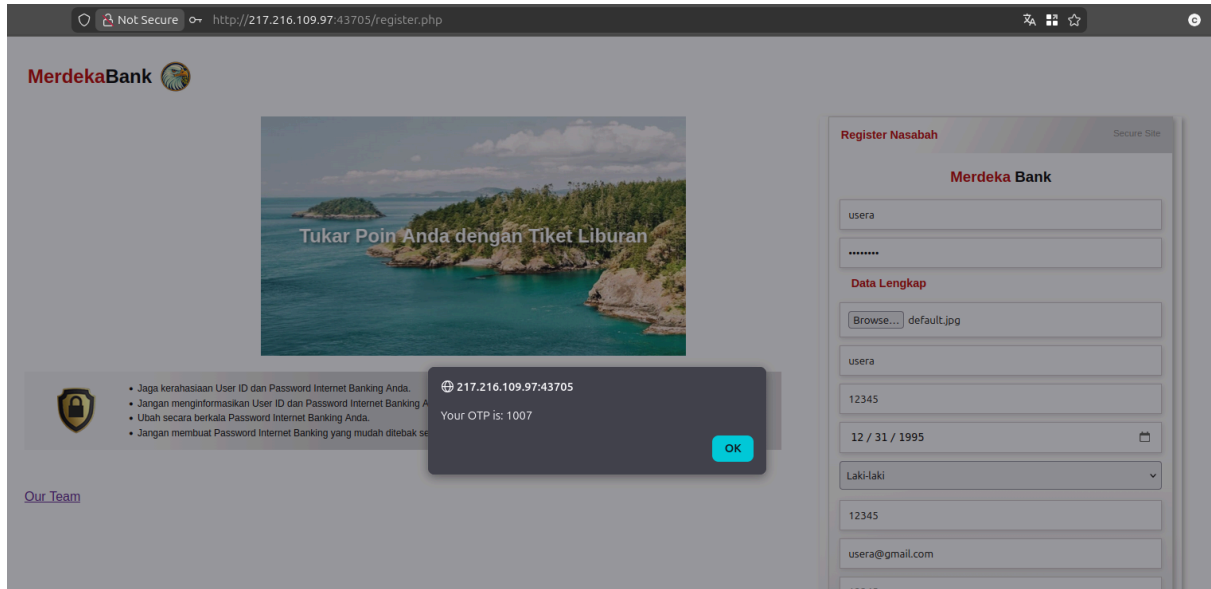
Authentication Bypass	
Severity	CRITICAL (9.8)
CVSS Score 3.1	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
Deskripsi	Authentication Bypass (Melewati Otentikasi) adalah jenis kerentanan keamanan di mana seorang penyerang dapat mengakses sumber daya atau fungsionalitas aplikasi web tanpa harus memberikan kredensial yang valid (seperti <i>username</i> dan <i>password</i>) atau tanpa melewati mekanisme verifikasi yang diwajibkan (seperti OTP atau MFA).

	Dalam hal ini kami berhasil bypass tahap memasukkan OTP ketika login
Affected URL	http://217.216.109.97:21513/login.php
Dampak	• Account Takeover: Seharusnya OTP menjadi otentikasi tambahan dalam proses login, namun melalui user enumeration dan bruteforcing dari kerentanan sebelumnya, jika data kredensial login berhasil didapatkan maka penyerang akan dengan sangat mudah masuk ke akun pengguna yang bocor • Confidentiality Breach: Setelah membobol akun pengguna, penyerang akan memiliki akses data sensitif yang bisa disalahgunakan • Kerugian Reputasi dan Kepatuhan: Kegagalan pada mekanisme keamanan yang paling mendasar akan menyebabkan denda dan hilangnya kepercayaan.
Kategori	Website
Rekomendasi	• Verifikasi Otentikasi yang Ketat: Terapkan prinsip <i>Fail Secure</i>: jika proses otentikasi gagal, akses harus ditolak secara tegas. Selalu verifikasi bahwa

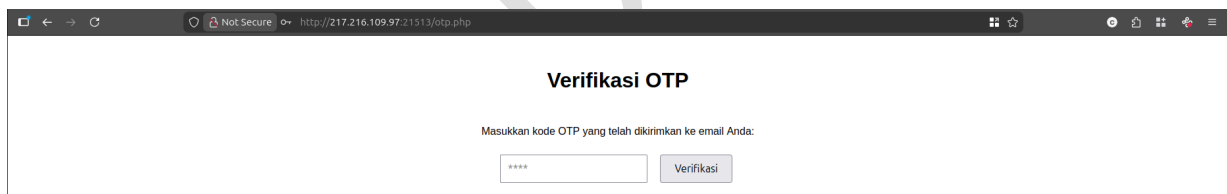
	pengguna benar-benar terotentikasi sebelum mengizinkan akses ke <i>endpoint</i> atau halaman yang sensitif. • Manajemen Sesi yang Aman: terapkan <i>timeout</i> sesi yang wajar, dan segera membuat <i>token</i> sesi baru setelah <i>login</i> berhasil untuk mencegah <i>Session Fixation</i>.
Referensi	• OWASP A07:2021 – Identification and Authentication Failures (https://owasp.org/Top10/A07_2021-Identification_and_Authentication_Failures/) • CWE-287: Improper Authentication (https://cwe.mitre.org/data/definitions/287.html) • NIST SP 800-53 (https://csrc.nist.gov/publications/sp-800-53) • CAPEC-473: Session/Authentication Abuse & CAPEC-598: Bypass Mechanism in Authentication (https://capec.mitre.org/data/definitions/473.html) • OWASP Authentication Cheat Sheet (https://cheatsheetseries.owasp.org/cheatsheets/Authentication_Cheat_Sheet.html)

Bukti Temuan

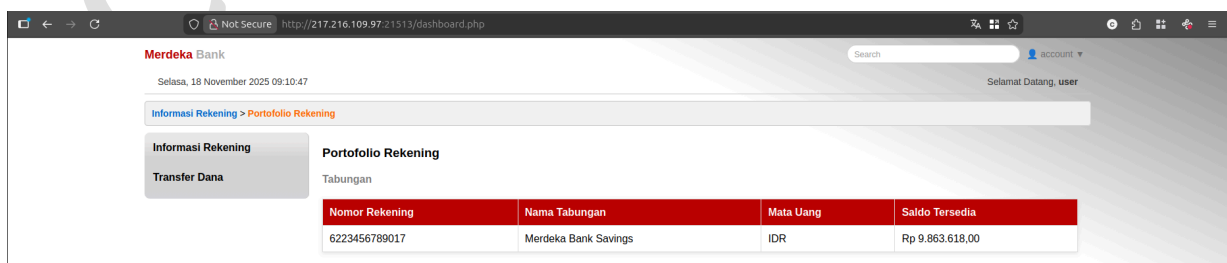
OTP untuk login diberikan setelah proses register



OTP akan diminta ketika proses login



Namun OTP bisa di-bypass dengan kembali ke halaman login dan memasukkan kredensial yang sama atau dengan klik "Login"



Status
OPEN

1.6.4 Information Disclosure

Information Disclosure	
Severity	HIGH 7.5
CVSS Score 3.1	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N
Deskripsi	Information Disclosure adalah kerentanan di mana aplikasi web secara tidak sengaja mengungkapkan data sensitif kepada pengguna yang tidak berwenang. Data ini bisa berupa informasi tentang sistem (seperti konfigurasi, <i>path</i> file, <i>stack trace</i>) atau informasi tentang pengguna (seperti PII, <i>token</i> sesi). Dalam konteks kerentanan ini, Aplikasi web membocorkan data sensitif kepada pengguna yang tidak berwenang. Data yang diekspos di sini adalah detail internal atau data sensitif berlebihan yang dimuat di sisi klien (melalui kode Java Script).
Affected URL	http://217.216.109.97:43705/index.js

Dampak	• Pengumpulan Kecerdasan (Intelligence Gathering): Penyerang dapat menemukan kunci API, URL <i>endpoint</i> internal, versi <i>framework</i>, atau detail konfigurasi yang membantu mereka merencanakan serangan lain (misalnya, mencoba mengeksploitasi <i>endpoint</i> yang tersembunyi). • • Hal ini sangat relevan melihat file JavaScript dapat dengan mudah diakses.
Kategori	Website
Rekomendasi	Hanya Kirim Data yang Dibutuhkan: Terapkan prinsip <i>least privilege</i> pada data yang dikirimkan ke <i>client-side</i>. Filter dan bersihkan semua objek data di sisi <i>server</i> sebelum dikirimkan. Misalnya, jika Anda hanya perlu menampilkan nama pengguna, pastikan Anda hanya mengirim <code>{"name": "..."} </code>, bukan <code>{"id": 123, "name": "...", "password_hash": "..."} </code>. Variabel Lingkungan Server-Side: Pastikan kunci API, kredensial <i>database</i>, dan <i>token</i> rahasia lainnya tidak pernah dimasukkan ke dalam kode JavaScript yang dikirim ke <i>browser</i>. Semua rahasia

	harus disimpan sebagai variabel lingkungan di sisi <i>server</i>. Hapus Informasi <i>Debugging</i>: Pastikan semua informasi <i>debugging</i> (<i>debug data</i>), <i>logging</i> berlebihan, atau <i>comment</i> internal yang sensitif telah dihapus sebelum <i>deployment</i> ke lingkungan produksi.
Referensi	• CWE-200: Exposure of Sensitive Information to an Unauthorized Actor (https://cwe.mitre.org/data/definitions/200.html) • OWASP A04:2021 – Insecure Design (https://owasp.org/Top10/A04_2021-Insecure_Design/) • NIST SP 800-53 (https://csrc.nist.gov/publications/sp-800-53) • CAPEC-119: Infrastructure Attack (https://capec.mitre.org/data/definitions/119.html)
Bukti Temuan	

Terdapat banyak informasi seperti debugging dan comment yang tidak difilter atau dibersihkan pada website production

```

// Menangani pengiriman form
form.addEventListener('submit', async (e) => {
    e.preventDefault(); // Mencegah form melakukan submit secara default
    const username = usernameInput.value;
    const password = passwordInput.value;
    const url = 'dashboard.php'; // URL sudah ditentukan langsung

    // Hello Gussy Qzhbba9pH6i1ic8Mia2F7c0Kx2Fuc8U0M65KxV180W=
    const formData = new FormData();
    formData.append('user', username);
    formData.append('pass', password);
    formData.append('url', url);

    try {
        // Mengirimkan request POST menggunakan fetch
        const response = await fetch(`${urlBase}routes/api.php/route=login`, {
            method: 'POST',
            body: formData, // Tidak perlu menambahkan headers untuk multipart
        });
        const textData = await response.text(); // Mengambil teks dari respons
        const data = JSON.parse(textData); // Parsing JSON dari respons

        // Mengecek status pada respons
        if (data.status === 'success') {
            const token = data.token; // Misalnya token disertakan dalam respons
            sessionStorage.setItem('authToken', token); // Menyimpan token ke sessionStorage
            messageDiv.textContent = data.message; // Menampilkan pesan sukses
            messageDiv.style.color = 'green';

            if (data.flag) {
                localStorage.setItem('flag', data.flag.flag);
                setTimeout(() => {
                    window.location.href = 'redir.php'; // Redirect ke dashboard
                }, 1000);
            } else {
                setTimeout(() => {
                    window.location.href = url; // Redirect ke dashboard
                }, 1000);
            }
        } else {
            messageDiv.textContent = data.message + "data.flag.flag"; // Menampilkan pesan error
            messageDiv.style.color = 'red';
        }
    } catch (error) {
        console.error(error);
        messageDiv.textContent = 'Terjadi kesalahan. Silakan coba lagi nanti.'; // Menangani error jaringan
        messageDiv.style.color = 'red';
    }
});
    
```

Status

OPEN

1.6.5 Insecure Direct Object Reference

Insecure Direct Object Reference

Severity

HIGH (7.6)

CVSS Score 3.1

CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:N

Deskripsi

Insecure Direct Object Reference (IDOR) adalah jenis kerentanan kontrol akses di mana aplikasi web

	mengekspos referensi langsung ke objek implementasi internal, dan gagal memverifikasi bahwa pengguna memiliki otorisasi untuk mengakses objek tersebut. Dalam hal ini kami dapat mengakses data pengguna diluar sesi dan login yang berjalan.
Affected URL	http://217.216.109.97:43705/dashboard.php
Dampak	• Pencurian Data Skala Besar: Penyerang dapat membuat <i>skrip</i> otomatis untuk mengulang melalui ID (misalnya dari 1 hingga 1.000.000) dan mengekstrak semua data sensitif milik pengguna, dalam hal ini, nama lengkap, tanggal lahir, email, alamat lengkap dan NIK • Kerugian Kepatuhan: Pelanggaran data yang disebabkan oleh IDOR hampir selalu melanggar peraturan kepatuhan data utama (seperti GDPR, HIPAA, atau PCI DSS).
Kategori	Website
Rekomendasi	• Verifikasi Kontrol Akses Setiap kali <i>input</i> pengguna digunakan untuk mengambil objek dari <i>database</i> server harus secara eksplisit memeriksa bahwa ID pengguna

	yang saat ini login adalah pemilik objek yang diminta. • Gunakan <i>Indirect Reference Maps</i> Agar tidak mengekspos ID database secara langsung (misalnya, <code>?id=123</code>), gunakan identifier yang tidak dapat diprediksi (unpredictable) seperti UUID (Universally Unique Identifier) atau reference map yang terpisah.
Referensi	• OWASP A01:2021 – Broken Access Control (https://owasp.org/Top10/A01_2021-Broken_Access_Control/) • CWE-639: Authorization Bypass Through User-Controlled Key (https://cwe.mitre.org/data/definitions/639.html) • NIST 800-53 (https://csrc.nist.gov/publications/sp-800-53) • CAPEC-49: Input Data Manipulation (https://capec.mitre.org/data/definitions/49.html) • OWASP IDOR Prevention Cheat Sheet (https://cheatsheetseries.owasp.org/cheatsheets/Insecure_Direct_Object_Reference_Prevention_Cheat_Sheet.html)
Bukti Temuan	

Mengubah parameter “customer_id” akan memunculkan data user lain

The screenshot shows a Burp Suite interface with a target URL of http://217.216.109.97:43705. The request is a POST to /dashboard.php with a multipart/form-data body. The response is a 200 OK status with a JSON body containing user information.

Request:

```

1 7 Referer: http://217.216.109.97:43705/dashboard.php
2 Content-Type: multipart/form-data; boundary=----geckoformboundary64aa007393b624276f456a7f00f90212
3 Content-Length: 344
4 Origin: http://217.216.109.97:43705
5 Connection: keep-alive
6 Cookie: session=3475c131.4ed8:4327-bb2a-e734f1d0eb9d.cBEb04TjF0C0yh2h1FRvS4wC56:
7 Priority: u=4
8 -----geckoformboundary64aa007393b624276f456a7f00f90212
9 Content-Disposition: form-data; name="token"
10 911f9fa6129ef4c278bcd67a704e81e3c143c9f2f9acffa03334059c1824ca
11 -----geckoformboundary64aa007393b624276f456a7f00f90212
12 Content-Disposition: form-data; name="customer_id"
13 1
14 -----geckoformboundary64aa007393b624276f456a7f00f90212--
  
```

Response:

```

1 HTTP/1.1 200 OK
2 Date: Mon, 17 Nov 2025 16:36:49 GMT
3 Server: Apache/2.4.56 (Debian)
4 X-Powered-By: PHP/8.0.30
5 Access-Control-Allow-Origin: *
6 Access-Control-Allow-Methods: GET, POST, OPTIONS, PUT, DELETE
7 Access-Control-Allow-Headers: Content-Type, Authorization, X-Requested-With
8 Vary: Accept-Encoding
9 Content-Length: 417
10 Keep-Alive: timeout=5, max=100
11 Connection: Keep-Alive
12 Content-Type: text/html; charset=UTF-8
13
14 {"status":"success","data":{"customer_id":"1","url_photo_profile":"gambarlakil.jpg","full_name":"Andi Setiawan","nik":"3175012312345678","date_of_birth":"1990-04-12","gender":"male","phone":"082234567898","email":"andi.setiawan@email.com","address":"Jl. mega bmkg","marital_status":"single","occupation":"CEO & Founder","nationality":"Indonesia","created_at":"2024-11-16 15:22:49","updated_at":"2024-11-24 14:59:11"}}
  
```

Status

OPEN

1.6.6 Insecure Direct Object Reference

Insecure Direct Object Reference

Severity

HIGH (7.6)

CVSS Score 3.1

CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:N

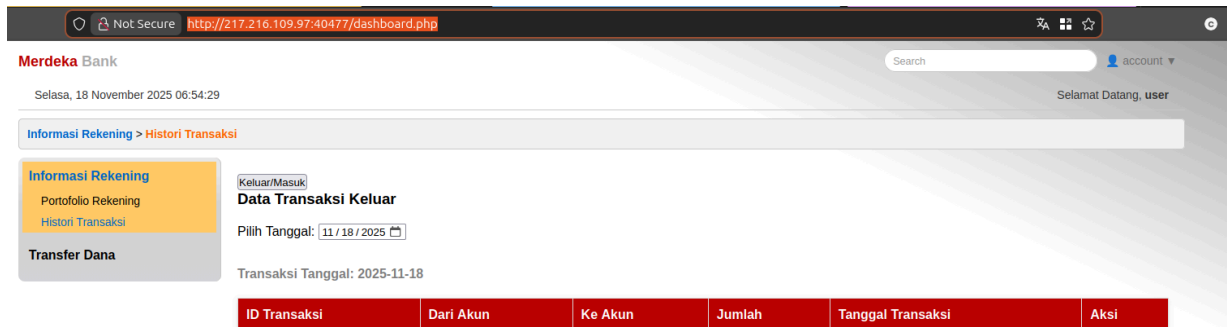
Deskripsi

Insecure Direct Object Reference (IDOR) adalah jenis kerentanan kontrol akses di mana aplikasi web mengekspos referensi langsung ke objek implementasi

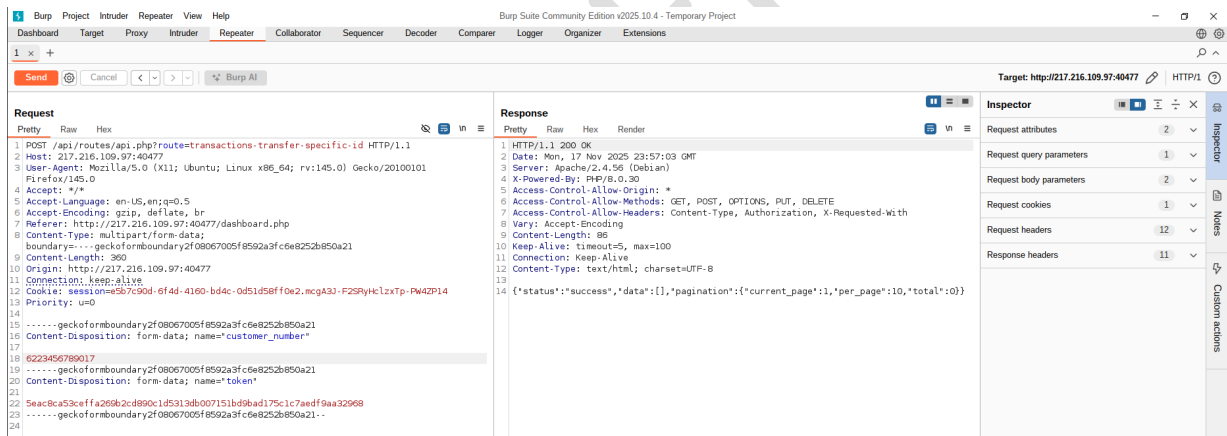
	internal, dan gagal memverifikasi bahwa pengguna memiliki otorisasi untuk mengakses objek tersebut. Dalam hal ini kami dapat mengakses data pengguna diluar sesi dan login yang berjalan.
Affected URL	http://217.216.109.97:40477/dashboard.php
Dampak	• Pencurian Data Skala Besar: Penyerang dapat membuat <i>skrip</i> otomatis untuk mengulang melalui ID (misalnya dari 1 hingga 1.000.000) dan mengekstrak semua data sensitif milik pengguna, dalam hal ini, nama lengkap, tanggal lahir, email, alamat lengkap dan NIK • Kerugian Kepatuhan: Pelanggaran data yang disebabkan oleh IDOR hampir selalu melanggar peraturan kepatuhan data utama (seperti GDPR, HIPAA, atau PCI DSS).
Kategori	Website
Rekomendasi	• Verifikasi Kontrol Akses Setiap kali <i>input</i> pengguna digunakan untuk mengambil objek dari <i>database</i> server harus secara eksplisit memeriksa bahwa ID pengguna

	yang saat ini login adalah pemilik objek yang diminta. • Gunakan <i>Indirect Reference Maps</i> Agar tidak mengekspos ID database secara langsung (misalnya, <code>?id=123</code>), gunakan identifier yang tidak dapat diprediksi (unpredictable) seperti UUID (Universally Unique Identifier) atau reference map yang terpisah.
Referensi	• OWASP A01:2021 – Broken Access Control (https://owasp.org/Top10/A01_2021-Broken_Access_Control/) • CWE-639: Authorization Bypass Through User-Controlled Key (https://cwe.mitre.org/data/definitions/639.html) • NIST 800-53 (https://csrc.nist.gov/publications/sp-800-53) • CAPEC-49: Input Data Manipulation (https://capec.mitre.org/data/definitions/49.html) • OWASP IDOR Prevention Cheat Sheet (https://cheatsheetseries.owasp.org/cheatsheets/Insecure_Direct_Object_Reference_Prevention_Cheat_Sheet.html)
Bukti Temuan	

Terdapat fitur pengecekan history transaksi pada browser



Menggunakan Burpsuite, parameter {customer_number} dapat diganti dan menampilkan data user lain diluar session dan ID yang terlogin
customer_number=6223456789017



customer_number=6223456789012

1

Burp

Project

Intruder

Repeater

View

Help

Dashboard

Target

Proxy

Intruder

Repeater

Collaborator

Sequencer

Decoder

Comparer

Logger

Organizer

Extensions

Burp Suite Community Edition v2025.10.4 - Temporary Project

Send

@

Cancel

<

>

Burp AI

Request

Inspector

1 POST /api/routes/api.php?route=transactions-transfer-specific-id HTTP/1.1

2 Host: 217.216.109.97:40477

3 User-Agent: Mozilla/5.0 (X11; Ubuntu; Linux x86_64; rv:145.0) Gecko/20100101 Firefox/145.0

4 Accept: */*

5 Accept-Language: en-US,en;q=0.5

6 Accept-Encoding: gzip, deflate, br

7 Referer: http://217.216.109.97:40477/dashboard.php

8 Content-Type: multipart/form-data;

9 Content-Length: 360

10 Origin: http://217.216.109.97:40477

11 Connection: keep-alive

12 Cookie: session=5b7c90d-6f4d-4160-bd4c-0d51d58ff0e2.ncgA3J-F2SPyKlzxTp-PW4ZP14

13 Priority: u=0

14geckoformboundary2f08067005f8592a3fc6e8252b850a21

15 Content-Disposition: form-data; name="customer_number"

16 6223456789012

17geckoformboundary2f08067005f8592a3fc6e8252b850a21

18 Content-Disposition: form-data; name="token"

19 5eac8ca53ceffa269b2cd890c1d5313db007151bd9bad175c1c7aeidf9aa32968

20geckoformboundary2f08067005f8592a3fc6e8252b850a21

21

22

23

24

1 HTTP/1.1 200 OK

2 Date: Mon, 17 Nov 2025 23:58:33 GMT

3 Server: Apache/2.4.56 (Debian)

4 X-Powered-By: PHP/8.0.30

5 Access-Control-Allow-Origin: *

6 Access-Control-Allow-Methods: GET, POST, OPTIONS, PUT, DELETE

7 Access-Control-Allow-Headers: Content-Type, Authorization, X-Requested-With

8 Vary: Accept-Encoding

9 Content-Length: 3255

10 Keep-Alive: timeout=5, max=100

11 Connection: Keep-Alive

12 Content-Type: text/html; charset=UTF-8

13

14 {"status":"success","data":[{"transaction_id":"19","account_id":"6223456789012","account_to":"109004","amount":"7.00","transaction_for":"","transaction_date":"2024-11-24 15:41:08","description":"Tokopedia","reference_number":"423778","balance_after":"172099.49.00","account_to_type":"virtual_account","account_type":"customer_account"},{"transaction_id":"17","account_id":"6223456789012","account_to":"6223456789014","amount":"20000.00","transaction_for":"","transaction_date":"2024-11-24 15:40:12","description":"Tokobuku","reference_number":"591658","balance_after":"17229956.00","account_to_type":"customer_account","account_type":"customer_account"},{"transaction_id":"18","account_id":"6223456789012","account_to":"6223456789014","amount":"20000.00","transaction_for":"","transaction_date":"2024-11-24 15:40:12","description":"Tokobuku","reference_number":"591658","balance_after":"17209956.00","account_to_type":"customer_account","account_type":"customer_account"},{"transaction_id":"16","account_id":"6223456789012","account_to":"109004","amount":"7000.00","transaction_for":"transfer","transaction_date":"2024-11-24"}]}

Inspector

Request attributes

Request query parameters

Request body parameters

Request cookies

Request headers

Response headers

Status

OPEN

1.6.7 Business Logic Flaw

Business Logic Flaw	
Severity	HIGH 7.1
CVSS Score 3.1	CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:N/I:H/A:L
Deskripsi	Business Logic Flaw adalah jenis kerentanan di mana penyerang mengeksploitasi cacat atau kelemahan dalam implementasi logika inti dari aplikasi, bukan pada masalah teknis umum seperti injeksi (<i>injection</i>) atau <i>buffer overflow</i> .

	Logika bisnis adalah aturan dan proses yang menentukan cara aplikasi beroperasi dan memproses transaksi di dunia nyata. Dalam hal ini kami berhasil memanipulasi pembayaran pada virtual account dimana seharusnya total pembayaran sudah ditentukan sebelumnya (fixed).
Affected URL	http://217.216.109.97:40477/dashboard.php
Dampak	• Fraud Finansial: Seperti skenario manipulasi harga atau transfer dana yang tidak sah.
Kategori	Website
Rekomendasi	• Validasi Harga di Sisi Server: Ketika request pembelian diterima, server harus mengambil harga yang benar dari database (atau sumber data terpercaya) dan menggunakannya untuk semua perhitungan. Harga yang dikirimkan oleh client harus diabaikan untuk tujuan perhitungan akhir. • Verifikasi Integritas Data: Gunakan checksum atau hash untuk memastikan parameter sensitif tidak diubah dalam perjalanan dari client ke server.

Referensi

- OWASP A04:2021 – Insecure Design (https://owasp.org/Top10/A04_2021-Insecure_Design/)
- CWE-440: Expected Behavior Violation (<https://cwe.mitre.org/data/definitions/440.html>)
- NIST 800-53 (<https://csrc.nist.gov/publications/sp-800-53>)
- CAPEC-49: Input Data Manipulation (<https://capec.mitre.org/data/definitions/49.html>)

Bukti Temuan

Terdapat fitur “Transfer Dana” ke Virtual Account pada halaman /dashboard.php

The screenshot shows the 'Transfer Bank' interface on the Merdeka Bank web application. The sidebar on the left contains 'Informasi Rekening' and 'Transfer Dana' (highlighted). The main content area is titled 'Transfer Bank' and includes a 'Sumber Dana' section with the following details:

- Nomor Rekening: 6223456789017
- Nama: Merdeka Bank Savings
- Mata Uang: IDR
- Saldo Tersedia: Rp 1.712.830,00
- Virtual Account: 109004

Below this, there is a 'Detail Virtual Account' table with the following data:

Detail Virtual Account	
Nomor Virtual Account	109004
Nama Barang	Tablet Apple iPad
Jumlah Tagihan	7000000.00
Untuk Pembayaran	Belanja
Jenis Pembayaran	receive
Gateway Pembayaran	Tokopedia
Tanggal Pembayaran	2024-11-10 12:00:00
Tanggal Dibuat	2024-11-16 22:36:18
Tanggal Diperbarui	2024-11-24 12:40:33

A red 'Transfer' button is located at the bottom right of the interface.

Menggunakan Burpsuite Intercept kami bisa merubah parameter {amount}, contoh dari “7000000,00” ke “700,00” dan ketika request diteruskan akan menghasilkan status code “200 OK”

The image shows two screenshots. The top screenshot is from Burp Suite, displaying an intercepted HTTP request and its response. The request is a POST to http://217.216.109.97:40477/dashboard.php. The response is a 200 OK status with a JSON body indicating a successful transaction: {"status": "success", "message": "Transaction created successfully.", "flag": "Chall 10: merdeka(p3kling_th3_4ctivity)"}. The bottom screenshot is from a web browser showing the 'Transfer Bank' page. It displays account details for 'Sumber Dana' (109004) and 'Rekening Tujuan/Virtual Account' (109004). A table shows transaction details: Nama Barang (Tablet Apple iPad), Jumlah Tagihan (7000000.00), Untuk Pembayaran (Belanja), Jenis Pembayaran (receive), Gateway Pembayaran (Tokopedia), Tanggal Pembayaran (2024-11-10 12:00:00), Tanggal Dibuat (2024-11-16 22:36:18), and Tanggal Diperbarui (2024-11-24 12:40:33). A green message 'Transaction successful' and a red 'Transfer' button are also visible.

dan dapat dikonfirmasi pada History Transaksi

Status
OPEN

1.6.8 Unrestricted File Upload

Unrestricted File Upload	
Severity	MEDIUM (4.6)
CVSS Score 3.1	CVSS:3.1/AV:N/AC:L/PR:L/UI:L/S:U/C:L/I:L/A:N
Deskripsi	Unrestricted File Upload adalah kerentanan yang terjadi ketika aplikasi web mengizinkan pengguna untuk mengunggah berkas ke <i>server</i> tanpa validasi yang memadai terhadap jenis (<i>type</i>), format (<i>format</i>), atau konten dari berkas yang diunggah. Inti dari serangan ini adalah memungkinkan penyerang mengunggah berkas berbahaya (seperti <i>script shell</i> PHP/JSP) ke direktori yang dapat diakses publik, yang kemudian dapat dieksekusi oleh <i>server web</i>. Dalam hal ini kami berhasil upload file dengan ekstensi .html
Affected URL	http://217.216.109.97:43705/edit-profile.php

Dampak	• Remote Code Execution (RCE): Ini adalah dampak terburuk. Penyerang dapat mengunggah dan menjalankan <i>webshell</i>, memberikan mereka akses tingkat <i>command-line</i> ke sistem operasi <i>server</i>. • Pengambilalihan Server (Server Compromise): Setelah mendapatkan RCE, penyerang dapat membaca berkas sensitif, memodifikasi konfigurasi, dan menggunakan <i>server</i> sebagai <i>pivot</i> untuk menyerang sistem internal lainnya dalam jaringan (<i>Internal Network</i>). • Defacement dan Denial of Service (DoS): Penyerang dapat merusak tampilan <i>website</i> atau mengunggah <i>file</i> yang sangat besar untuk menghabiskan sumber daya <i>disk</i>.
Kategori	Website
Rekomendasi	• Filter file yang bisa diupload ke server Hanya izinkan ekstensi dan jenis MIME yang mutlak diperlukan (misalnya, <i>.jpg</i>, <i>.png</i>, <i>.pdf</i>). Kemudian periksa jenis MIME (misalnya, <i>image/jpeg</i>) di sisi <i>server</i> dan verifikasi bahwa jenis MIME tersebut benar-benar cocok dengan isi <i>file</i>. • Konversi nama file yang diunggah Hal ini untuk menghindari dari path traversal atau

	enumeration attack karena nama file yang mudah ditebak, bisa gunakan UUID • Batasi ukuran file Menghindari dari kemungkinan Denial-of-Service menggunakan file dengan size sangat besar
Referensi	• OWASP A08:2021 – Software and Data Integrity Failures (https://owasp.org/Top10/A08_2021-Software_and_Data_Integrity_Failures/) • CWE-434: Unrestricted Upload of File with Dangerous Type (https://cwe.mitre.org/data/definitions/434.html) • NIST 800-53 (https://csrc.nist.gov/publications/sp-800-53) • CAPEC-24: File Upload Attack (https://capec.mitre.org/data/definitions/24.html) • OWASP File Upload Vulnerability Cheat Sheet (https://cheatsheetseries.owasp.org/cheatsheets/File_Upload_Vulnerability_Cheat_Sheet.html)
Bukti Temuan	

Berhasil upload file HTML

The screenshot shows the Burp Suite interface with the HTTP history tab selected. A list of requests is shown, with the selected request being a POST to /api/routes/api.php?route=login. The response is a 200 status code with a Content-Type of text/html. The HTML body contains a script tag that triggers an alert.

Status

OPEN

1.6.9 Cross-Site Scripting (XSS) – Reflected

Cross-Site Scripting (XSS) – Reflected

Severity

MEDIUM (4.3)

CVSS Score 3.1

CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:L/I:L/A:N

Deskripsi

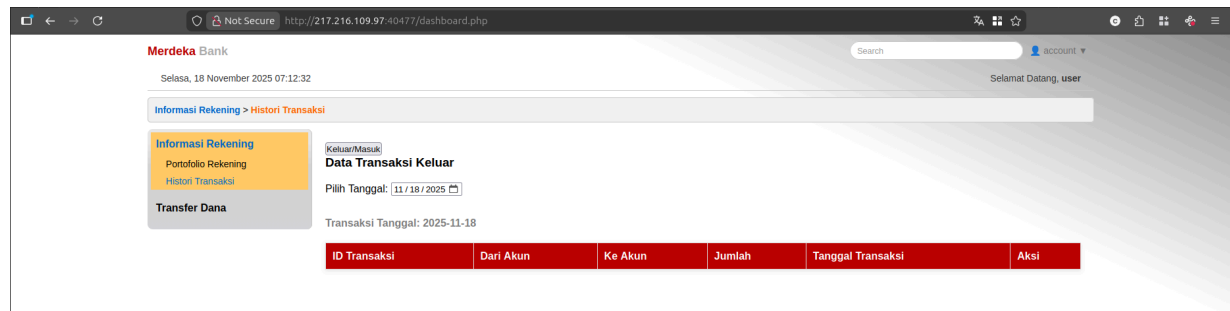
Cross-Site Scripting (XSS) adalah kerentanan keamanan web yang memungkinkan penyerang

	menyuntikkan (<i>inject</i>) <i>script</i> sisi klien (umumnya JavaScript) ke dalam halaman web yang dilihat oleh pengguna lain. Kerentanan ini terjadi ketika aplikasi web gagal memvalidasi, membersihkan (<i>sanitize</i>), atau meng-<i>encode</i> data yang dimasukkan oleh pengguna sebelum menampilkannya kembali di halaman web. Dalam hal ini kami menemukan payload XSS dapat dieksekusi melalui search field
Affected URL	http://217.216.109.97:40477/dashboard.php
Dampak	• Pencurian Cookie Sesi: Penyerang dapat mencuri <i>cookie</i> sesi korban (<i>document.cookie</i>), yang seringkali berisi <i>token</i> otentikasi. Hal ini memungkinkan penyerang untuk membajak sesi (<i>session hijacking</i>) korban dan mengambil alih akun. • Defacement dan Pengubahan Konten: Skrip dapat mengubah tampilan halaman web atau mengalihkan (<i>redirect</i>) korban ke situs <i>phishing</i> berbahaya. • Eksekusi Script Berbahaya: Penyerang dapat memaksa <i>browser</i> korban melakukan tindakan

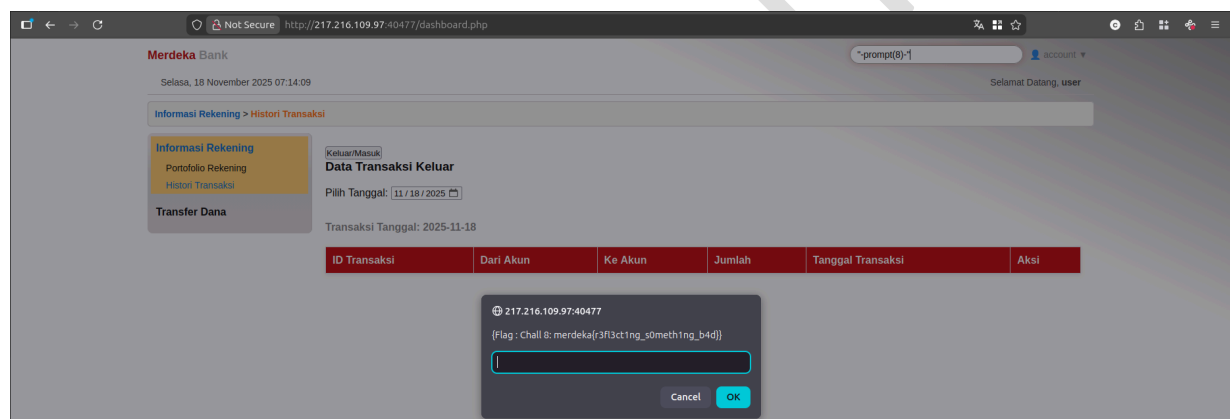
	yang seharusnya hanya dapat dilakukan oleh korban (misalnya, mengirim <i>request</i> HTTP yang tidak terlihat).
Kategori	Website
Rekomendasi	Pengodean Output (Output Encoding): Ini adalah mitigasi paling penting. Sebelum menampilkan <i>input</i> pengguna kembali ke halaman HTML, pastikan semua karakter khusus (seperti <, >, ', dan ") di-<i>encode</i> menjadi entitas HTML (<i>HTML Entities</i>). Misalnya, <script> harus dikodekan menjadi &lt;script&gt;. Sanitasi Input: Jika aplikasi harus mengizinkan HTML (misalnya, untuk kolom komentar berformat), filter hapus semua <i>tag</i> dan atribut yang berbahaya. Implementasikan Content Security Policy (CSP): Terapkan <i>header</i> HTTP Content Security Policy (CSP) yang ketat. CSP memberitahu <i>browser</i> sumber daya (seperti <i>script</i>) mana yang diizinkan untuk dimuat dan dieksekusi, yang dapat memblokir skrip yang disuntikkan secara <i>inline</i> atau dari sumber yang tidak terpercaya.

Referensi	• OWASP A03:2021 – Injection (https://owasp.org/Top10/A03_2021-Injection/) • CWE-79: Improper Neutralization of Input During Web Page Generation ('Cross-site Scripting') (https://cwe.mitre.org/data/definitions/79.html) • NIST 800-53 (https://csrc.nist.gov/publications/sp-800-53) • CAPEC-85: ActiveX Attack (https://capec.mitre.org/data/definitions/85.html) • OWASP XSS Prevention Cheat Sheet (https://cheatsheetseries.owasp.org/cheatsheets/Cross_Site_Scripting_Prevention_Cheat_Sheet.html)
Bukti Temuan	

Terdapat fungsi pencarian di halaman dashboard pengguna



menggunakan payload XSS seperti {"-prompt(8)-"}, kita bisa mentrigger reflected XSS pada halaman tersebut



Status

OPEN

1.6.10 Cross-Site Scripting (XSS) - Stored

Cross-Site Scripting (Stored)

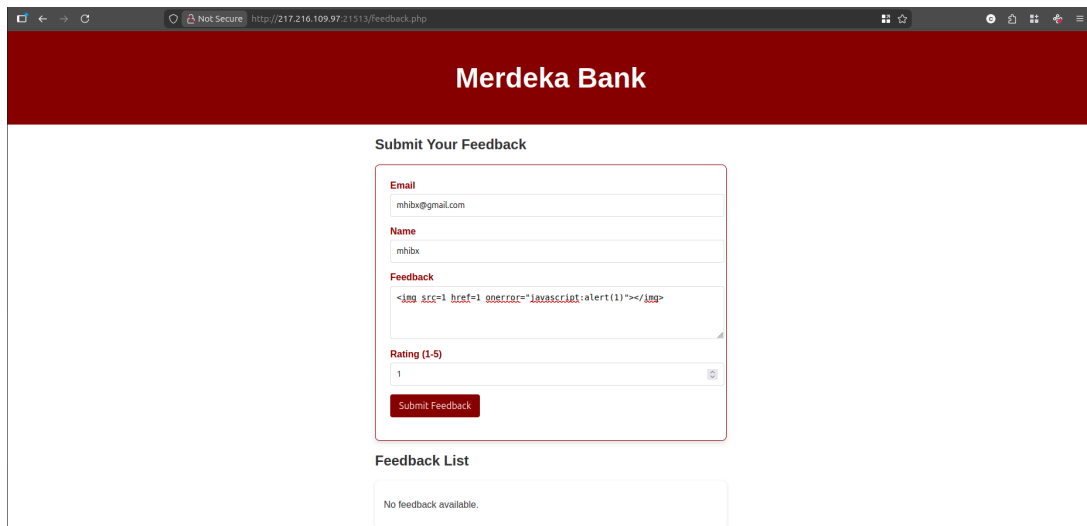
Severity	MEDIUM(6.8)
CVSS Score 3.1	CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:L/A:N
Deskripsi	Stored Cross-Site Scripting (XSS Tersimpan), juga dikenal sebagai Persistent XSS, terjadi ketika <i>payload</i> berbahaya (umumnya <i>script</i> JavaScript) yang disuntikkan oleh penyerang disimpan secara permanen di <i>server</i> aplikasi web (biasanya di <i>database</i>, sistem <i>file</i>, atau sumber data <i>backend</i> lainnya). Setiap kali pengguna lain memuat halaman web yang menampilkan konten yang terinfeksi tersebut, <i>server</i> akan mengambil <i>payload</i> dan mengirimkannya ke <i>browser</i> korban. <i>Browser</i> korban kemudian mengeksekusi <i>script</i> tersebut secara otomatis. Dalam hal ini kami menemukan celah XSS pada halaman ulasan yang dapat dikunjungi oleh semua pengguna tanpa perlu login
Affected URL	http://217.216.109.97:21513/feedback.php
Dampak	• Pencurian <i>Cookie</i> Sesi Massal: Karena <i>payload</i> XSS yang sangat banyak salah satu skenario yang memungkinkan adalah Penyerang dapat mencuri <i>cookie</i> sesi milik semua pengguna yang melihat

	<i>payload</i>, tidak menghindari kemungkinan akun admin juga terkena dampaknya jika melihat halaman <code>feedback.php</code> • Defacement dan Pengubahan Konten: Skrip dapat mengubah tampilan halaman web atau mengalihkan (<i>redirect</i>) korban ke situs <i>phishing</i> berbahaya. • Eksekusi Script Berbahaya: Penyerang dapat memaksa <i>browser</i> korban melakukan tindakan yang seharusnya hanya dapat dilakukan oleh korban (misalnya, mengirim <i>request</i> HTTP yang tidak terlihat).
Kategori	Website
Rekomendasi	• Pengodean Output (Output Encoding): Ini adalah mitigasi paling penting. Sebelum menampilkan <i>input</i> pengguna kembali ke halaman HTML, pastikan semua karakter khusus (seperti <code><</code>, <code>></code>, <code>'</code>, dan <code>"</code>) di-<i>encode</i> menjadi entitas HTML (<i>HTML Entities</i>). Misalnya, <code><script></code> harus dikodekan menjadi <code>&lt;script&gt;</code>. • Sanitasi Input: Jika aplikasi harus mengizinkan HTML (misalnya, untuk kolom komentar berformat), filter hapus semua <i>tag</i> dan atribut yang berbahaya.

	• Implementasikan <i>Content Security Policy</i> (CSP): Terapkan <i>header</i> HTTP Content Security Policy (CSP) yang ketat. CSP memberitahu <i>browser</i> sumber daya (seperti <i>script</i>) mana yang diizinkan untuk dimuat dan dieksekusi, yang dapat memblokir skrip yang disuntikkan secara <i>inline</i> atau dari sumber yang tidak terpercaya.
Referensi	• OWASP A03:2021 – Injection (https://owasp.org/Top10/A03_2021-Injection/) • CWE-79: Improper Neutralization of Input During Web Page Generation ('Cross-site Scripting') (https://cwe.mitre.org/data/definitions/79.html) • NIST 800-53 (https://csrc.nist.gov/publications/sp-800-53) • CAPEC-85: ActiveX Attack (https://capec.mitre.org/data/definitions/85.html) • OWASP XSS Prevention Cheat Sheet (https://cheatsheetseries.owasp.org/cheatsheets/Cross_Site_Scripting_Prevention_Cheat_Sheet.html)

Bukti Temuan

Terdapat fitur untuk memberikan feedback pada halaman /feedback.php, kami coba input payload XSS {} lalu klik "Submit Feedback"

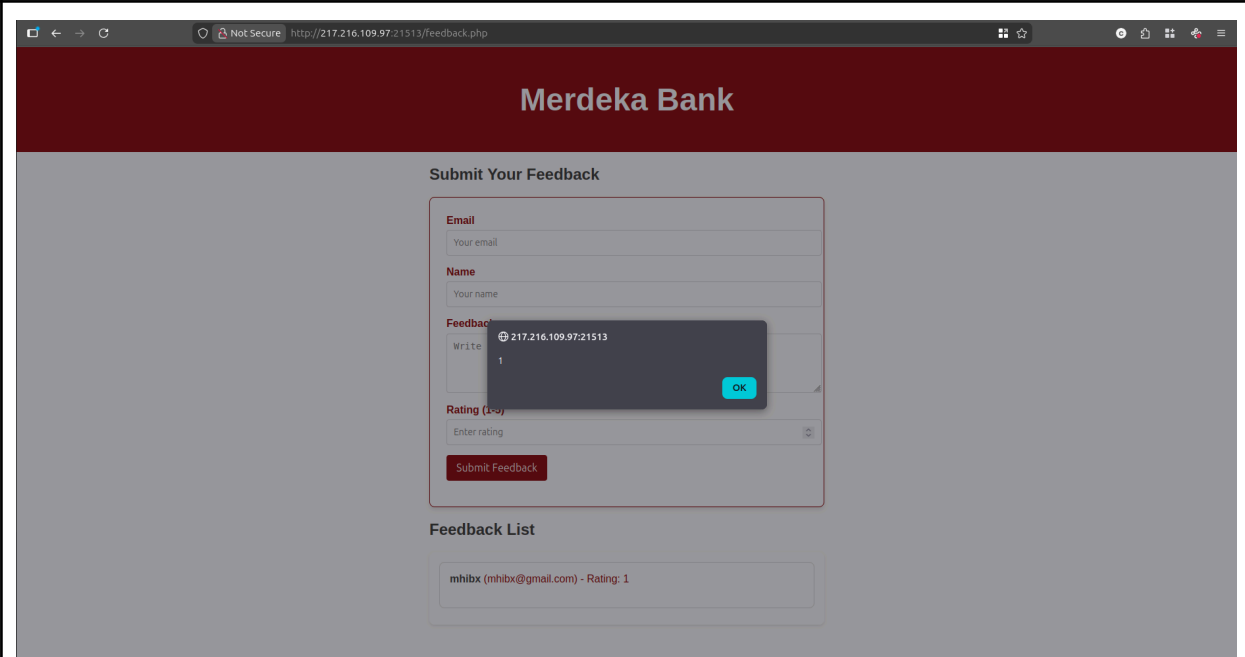


The screenshot shows a web browser window with the URL `http://217.216.109.97:21513/feedback.php`. The page has a red header with the text "Merdeka Bank". Below the header, there is a section titled "Submit Your Feedback". This section contains a form with the following fields:

- Email:** mhibx@gmail.com
- Name:** mhibx
- Feedback:**
- Rating (1-5):** 1

Below the form is a red "Submit Feedback" button. Underneath the form, there is a section titled "Feedback List" which displays "No feedback available.".

Payload XSS dieksekusi oleh website dan akan selalu dieksekusi selama feedback tampil di website kepada semua user yang mengunjunginya



The screenshot shows a web browser window with the URL `http://217.216.109.97:21513/feedback.php`. The page has a dark red header with the text "Merdeka Bank". Below the header is a "Submit Your Feedback" form. The form contains fields for "Email", "Name", "Feedback" (with a text area), and "Rating (1-5)". A red "Submit Feedback" button is at the bottom of the form. A security alert dialog box is overlaid on the form, displaying the IP address "217.216.109.97:21513" and an "OK" button. Below the form is a "Feedback List" section showing a single entry: "mhibx (mhibx@gmail.com) - Rating: 1".

Status
OPEN

1.6.11 Information Disclosure

Information Disclosure	
Severity	LOW (3.7)
CVSS Score 3.1	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N
Deskripsi	Information Disclosure adalah kerentanan di mana aplikasi web secara tidak sengaja mengungkapkan data sensitif kepada pengguna yang tidak berwenang. Data ini bisa berupa informasi tentang sistem (seperti

	konfigurasi, <i>path</i> file, <i>stack trace</i>) atau informasi tentang pengguna (seperti PII, <i>token</i> sesi). Dalam konteks kerentanan ini kami menemukan adanya pengungkapan secara eksplisit dalam proses otentikasi login, ketika input username tetap divalidasi walaupun input password salah. Hal ini menyebabkan website rentan terhadap serangan <i>user enumeration</i> dan <i>brute force</i>.
Affected URL	http://217.216.109.97:43705/login.php
Dampak	• Pembuatan Daftar Target: Penyerang dapat membuat daftar lengkap username valid (<i>valid user list</i>) yang ada di sistem Anda. • Serangan <i>Brute Force</i> yang Lebih Efektif: Setelah memiliki daftar <i>username</i> yang valid, penyerang dapat memfokuskan serangan <i>brute force</i> atau <i>dictionary attack</i> hanya pada <i>username</i> tersebut. • Serangan <i>Phishing/Social Engineering</i>: Mengetahui <i>username</i> yang valid memberikan kredibilitas lebih pada upaya <i>phishing</i> atau <i>social engineering</i> karena penyerang dapat membuat email yang lebih personal.

Kategori	Website
Rekomendasi	• Gunakan Pesan Generik: Pastikan <i>server</i> selalu merespons dengan satu pesan kegagalan yang sama, terlepas dari apakah <i>username</i> salah atau <i>password</i> yang salah. Contoh Pesan yang Aman: <code>{"status":"error","message":"Username atau password tidak ditemukan."}</code> (Atau "tidak valid"). • Batasi Percobaan (<i>Rate Limiting</i>): Implementasikan <i>rate limiting</i> pada halaman login untuk membatasi jumlah upaya login yang dapat dilakukan dari satu IP dalam periode waktu tertentu. Ini menghambat upaya serangan <i>brute force</i> dan <i>enumeration</i> yang dilakukan secara otomatis. • Waktu Respons Konstan (<i>Timing Attack Mitigation</i>): Pastikan waktu yang dibutuhkan <i>server</i> untuk merespons <i>username</i> valid dan <i>username</i> tidak valid sama (konstan). Ini mencegah penyerang mengukur perbedaan waktu pemrosesan sebagai petunjuk validasi <i>username</i>.
Referensi	• CWE-200: Exposure of Sensitive Information to an Unauthorized Actor (https://cwe.mitre.org/data/definitions/200.html)

- OWASP A04:2021 – Insecure Design
(https://owasp.org/Top10/A04_2021-Insecure_Design/)
- NIST SP 800-53
(<https://csrc.nist.gov/publications/sp-800-53>)
- CAPEC-119: Infrastructure Attack
(<https://capec.mitre.org/data/definitions/119.html>)

Bukti Temuan

Menggunakan username valid namun password yang salah menghasilkan response web:



```

Request  Response
Pretty  Raw    Hex    Render
1 HTTP/1.1 200 OK
2 Date: Mon, 17 Nov 2025 17:35:37 GMT
3 Server: Apache/2.4.56 (Debian)
4 X-Powered-By: PHP/8.0.30
5 Access-Control-Allow-Origin: *
6 Access-Control-Allow-Methods: GET, POST, OPTIONS, PUT, DELETE
7 Access-Control-Allow-Headers: Content-Type, Authorization, X-Requested-With
8 Vary: Accept-Encoding
9 Content-Length: 106
10 Keep-Alive: timeout=5, max=100
11 Connection: Keep-Alive
12 Content-Type: text/html; charset=UTF-8
13
14 {"status":"error","message":"Username ditemukan, tetapi password salah Chall 2: merdeka(g0t_r1gh7_u53r)."}
  
```

Status

OPEN

CONFIDENTIAL

CLOSING

Saat memulai proyek ini, **PT. Merdeka Siber Teknologi** berkomitmen untuk memenuhi dan menyampaikan laporan-laporan terbaik. Sementara itu, dengan kolaborasi yang baik dengan tim IT klien dan semua orang yang terlibat di dalamnya, kami berhasil menyelesaikannya. Kami menemukan beberapa kelemahan dalam aplikasi, yang terpisah di beberapa titik, berdasarkan skor CVSS 3.1 kami yang diadaptasi. Oleh karena itu, kami merekomendasikan untuk melakukan perbaikan sesuai dengan rekomendasi yang tercantum di atas, mengikuti kerentanan yang ditemukan dalam sistem. Penerapan rekomendasi ini harus menjadi faktor penting dalam peta jalan keamanan Anda di masa mendatang.

Kami juga merekomendasikan melakukan Penetration Testing minimal setahun sekali. Ini didasarkan pada standar internasional yang disarankan oleh peraturan praktisi. Sesuai dengan proposisi bisnis Anda, Anda juga dibebankan dan diwajibkan untuk melakukan hal tersebut sebagaimana diatur dalam ISO 270001. Dengan melakukan hal tersebut, **PT Merdeka Bank** dapat meningkatkan postur keamanannya untuk mengurangi kelemahan pada aplikasi dan menghindari serangan siber yang semakin canggih. Kami berharap dapat menjalin lebih banyak kerja sama dan kolaborasi dengan organisasi Anda di masa mendatang.

Thanks.